

Active Directory Attack Paths

The AD attack pantry (with often-abused facts)

Kerberoasting (T1558.003)

Find service accounts with SPNs; request a service ticket; the service's password hash (RC4/AES) lives in the ticket → crack offline.

```
impacket-GetUserSPNs -request domain/user:'P@ss' -dc-ip 10.0.0.30  
# -> save TGS-REP; crack with hashcat -m 13100 (RC4) or 19700 (AES)
```

AS-REP roasting (T1558.004)

Users with "Do not require Kerberos pre-authentication" – request their TGT, crack offline without their password.

```
impacket-GetNPUsers -usersfile users.txt -dc-ip 10.0.0.30 -format hashcat domain/
```

Pass-the-ticket / Golden ticket (T1558.001)

KRBTGT hash = forge ANY ticket for anyone, incl. domain admin. DCSync the krbtgt hash, then:

```
impacket-ticketer -nthash <krbtgt-ntlm> -domain-sid S-1-5-... -domain corp.local fakeadmin
```

Other favorites

Silver ticket: forge a service-level ticket (needs service hash)

Delegation abuse (unconstrained/constrained/RBCD): impersonate users via Kerberos delegation flags

GP0 abuse: push a malicious startup script or logon script via writable GP0

ACL abuse: modify another object's DACL (genericAll → reset password / add to group)

Enumeration drives attack

BloodHound (SharpHound / bloodhound-python) graphs who-can-reach-what.
Attack paths = edges.

Defenders' counter-play

Disable RC4; enforce AES

Rarely use pre-auth-disabled accounts

Stronger service account passwords (or gMSA – auto-rotated, can't Kerberoast easily)

Monitor ticket requests/paths (event 4769 with suspicious cipher/request type)

AD attacks are not magic – they are MySQL queries into your own directory's old defaults. Master these, and hardening AD becomes obvious.

[← Credential Dumping & Pass-th...](#)

[Linux Privilege Escalation →](#)